

# Development Activity 1 - Build and Host Your Project Prototype

Secure Software Development | 30 September 2026

## 1. Project Information

**Project Name** StaffHub - Employee Management System

**Group Members** 23F-3063 Ahsan Yasin; 23F-3100 Taneer Hussain

**Primary User Role** Employee

## 2. Live Website

**Public URL:** **[TO BE FILLED]**

## 3. Developed Pages

- 1The Home page introduces StaffHub's name, purpose and short description, with navigation, an Employee Login button and a footer.
- 2The Login page has email and password fields, an accessible show/hide password toggle, generic validation messaging and a prototype notice; it has no role dropdown because the server will decide roles later.
- 3The Employee Portal shows the employee's limited profile, leave balance cards, a Request Leave form, leave history with status badges and a status filter, team announcements, and a log-out button.

## 4. JavaScript Interactions

- 1The login-page show/hide toggle reveals or masks the password so an employee can check what they entered.
- 2Login validation checks email format and a non-empty password, then uses generic error wording to avoid disclosing authentication details.
- 3Leave validation requires the leave type and dates, rejects a past start date, and prevents an end date before the start date.
- 4A live character counter helps employees keep the optional leave reason brief and within 200 characters.
- 5A submitted leave request is added to history as Pending, giving the employee immediate feedback in the prototype.
- 6The history status filter helps employees find requests by their current status.
- 7A confirmation modal protects against accidentally cancelling a Pending leave request.
- 8The mobile navigation toggle keeps the employee's links accessible on narrow screens.

---

## 5. Security-Aware Design

- The interface exposes only the Employee view and fictional employee data; it shows no HR or Administrator links or functions. Hiding a button is not a security control.
- The password field uses type="password" and no hardcoded credentials are included. Login uses the generic message "Invalid email or password" and does not offer a role dropdown.
- User-entered leave text is added with textContent, not innerHTML, to reduce cross-site scripting (XSS) risk.
- The form collects only leave type, dates and a short optional reason, warns against medical details, and does not show salary, national ID, bank details or other employees' data.
- vercel.json configures Content-Security-Policy, X-Frame-Options, X-Content-Type-Options (nosniff), and Referrer-Policy headers.
- The future backend will enforce server-side RBAC, password hashing, HTTPS, input validation, CSRF protection and audit logging.

## 6. Testing

**Problem discovered during testing:** [TO BE FILLED]

**How I fixed it / improvement made:** [TO BE FILLED]